Weekly Cyber Threat Intelligence Report

Reporting window: 27 October - 2 November 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

PUBLIC

Source: CyberSec Vault automated intel sweep

Executive Summary

15	7	14	14	9	24
Critical CVEs	High-sev vulns	Actively exploited	Notable breaches	PoCs / tools	IOCs to add

This week's report covers **27 October - 2 November 2026**. Dominant themes: **runtime-level RCEs going straight to KEV** (PHP2Shell and Node2Shell, alongside GitLab CVSS 10, Oracle EBS, Drupal Commerce, Adobe Commerce, VMware and two more Ivanti chain CVEs), **developer tooling as the supply-chain front door** (a tampered Claude Code extension on Cursor's marketplace backdoored up to ~5,000 machines; Warp and Northflank vendor breaches; poisoned Hugging Face models and fake AI installers) and **DPRK crypto theft at record scale** - TraderTraitor drained ~USD 6.3B from Binance. AI now shows up on both sides: an unreleased Claude model built a remote-root Linux exploit, Chainalysis was breached via 'offensive agentic techniques', and stealers target AI-tool tokens. Network control planes stayed under fire (Cisco SD-WAN KeyDrift, ASA/FTD VPN zero-day, k0t FortiGate secrets, Volt Typhoon's Silent Train). Public-sector and healthcare losses: Florida 4.9M SSNs, DHS staff doxxing, Moldova, Belgium's tax portal and UNM Health diversions. APAC: Binance/DPRK, JAL and Sony in Japan's incident wave, Capcom 11.7M, NetamLoader against Asian governments and eMudhra's CA exit. Australia: AU agencies inside the Amadey backend.

KEY CALLOUTS - SECTOR IMPACT

Who is affected this week

OT / ICS & CRITICAL INFRASTRUCTURE

4 items

Pre-boot and control-plane exposure: EDK II PXE RCE needs OEM firmware, Dahua cameras hijacked at scale, Volt Typhoon relay chains, and new Hitachi/JCI/Moxa advisories.

- HIGH Dahua camera campaign: 14,500+ cameras hijacked in 35 days (CERT-UA warning)
- HIGH Volt Typhoon used 'Silent Train' on-demand relay chains to hide four zero-day campaigns
- CRIT wolfSSL WolfProt CVE-2026-59106: unauthenticated OS command injection (CVSS 9.3)
- MEDI ICS advisories: Hitachi, Johnson Controls, Moxa and Esri

HEALTHCARE

3 items

Availability hits again: UNM Health diverted ambulances; Quest and Charite lost patient/staff data.

- CRIT UNM Health cyber incident: patients diverted, 30+ clinics closed
- HIGH Quest Diagnostics: Quanum Lab Services Manager accessed, patient records exposed
- MEDI Charite Berlin: web server breach exposes staff, student and contact data

GOVERNMENT

10 items

Florida 4.9M SSNs, DHS staff doxxed, Moldova ~750k records, Belgian tax portal down, NetamLoader aimed at government-only Windows builds.

- CRIT Florida Student Financial Aid site breach: ~4.9M applicants incl. SSNs and DOBs
- HIGH Belgium FPS Finance takes MyMinfin offline after cyberattack; tax deadline extended
- HIGH Data on 41,000+ DHS (mostly ICE/CBP) employees published by 'Department of Peace'
- HIGH Moldova government systems breached; data of ~750,000 people reportedly stolen
- HIGH NetamLoader: .NET loader aimed at a government-only custom Windows 10 build in Asia
- MEDI Apple sends mercenary-spyware threat notifications to users in 99 countries
- MEDI Cyprus GigaVoucher grant programme: ~72,920 records leaked
- MEDI Dark-web claims: Indonesia President's Office documents and Malaysian Customs webshell access for sale

+ 2 more in the sections below

MANUFACTURING

2 items

- HIGH Holcim listed on Emperador ransomware leak site
- MEDI ICS advisories: Hitachi, Johnson Controls, Moxa and Esri

FINANCIAL

7 items

Binance USD 6.3B DPRK heist, Polymarket script drain, UNC6671 vishing against hedge funds, Chainalysis agentic intrusion.

- CRIT Binance loses ~USD 6.3B in largest crypto theft on record - attributed to DPRK TraderTraitor
- HIGH Belgium FPS Finance takes MyMinfin offline after cyberattack; tax deadline extended
- HIGH Chainalysis breached by 'offensive agentic techniques'
- HIGH Polymarket third-party script drained wallets and sold positions; ~USD 2.7M refunded
- HIGH UNC6671 (BlackFile-linked) help-desk vishing hits hedge funds and PE firms; CCCS alert AL26-028
- HIGH Wallet stealers: fake Firefox add-ons (Phantom, Jupiter, Bitget) and fake 'Padre Terminal' iOS app
- MEDI ZloyRAT Android trojan uses fuel, VPN and drone-radar lures in Russia (F6)

ENERGY / UTILITIES

2 items

- MEDI Engie partner sales tool breached; customer contract references stolen
- MEDI ICS advisories: Hitachi, Johnson Controls, Moxa and Esri

TRANSPORT / AVIATION

2 items

- HIGH Japan incident wave: JAL (via Amadeus, ~92,000 customers) and Sony Network Communications (~2.5M records)
- MEDI CTS Strasbourg transport: ~230,000 customer accounts stolen

TELECOM

5 items

- CRIT Cisco Catalyst SD-WAN auth bypass CVE-2026-20127 exploited by UAT-11473 to plant KeyDrift
- HIGH Android 'SMS of Death' CVE-2026-58882: crafted SMS crashes phones, can block emergency calls
- HIGH Android 'SMS of Death' PoC (CVE-2026-58882)
- HIGH Japan incident wave: JAL (via Amadeus, ~92,000 customers) and Sony Network Communications (~2.5M records)
- HIGH Volt Typhoon used 'Silent Train' on-demand relay chains to hide four zero-day campaigns

DEFENSE / AEROSPACE

1 item

- HIGH Dahua camera campaign: 14,500+ cameras hijacked in 35 days (CERT-UA warning)

EDUCATION

1 item

- CRIT Florida Student Financial Aid site breach: ~4.9M applicants incl. SSNs and DOBs

RETAIL / CONSUMER

7 items

- CRIT Adobe Commerce / Magento CVE-2026-48356 added to CISA KEV
- CRIT Drupal Commerce Core access bypass CVE-2026-118539 (Highly Critical) exploited against stores
- HIGH Capcom ID breach confirmed: 11.77M accounts (emails, last IP, login metadata)
- HIGH Telegram for Android: answering a voice call could trigger code execution
- HIGH Revolve Group 8-K: saved payment cards scraped via automated account access
- MEDI Intelbras IP cameras: unauthenticated firmware-upgrade endpoint enables LAN DoS
- MEDI Scribd (Slideshare/Everand) breach notices: emails, payment history, card last-4

TECHNOLOGY / SaaS / DEV

17 items

Developer tooling is the target: tampered Claude Code extension, Warp and Northflank vendor breaches, GitLab KEV, Node2Shell.

- CRIT Canonical LXD / MicroCloud CVE-2026-112816 (CVSS 10): trusted-client impersonation
- CRIT GitLab CVE-2026-97229 (CVSS 10) unauthenticated CI/CD regex RCE added to CISA KEV
- CRIT Node2Shell / Brotli2Shell (CVE-2026-111497): Node.js bundled Brotli decoder RCE exploited (KEV)
- CRIT Node2Shell RCE writeup and PoC inputs (Imperva) for CVE-2026-111497
- CRIT Tampered Claude Code VS Code extension (2.1.312 / 2.1.313) on Cursor marketplace planted SSH backdoors
- HIGH Chainalysis breached by 'offensive agentic techniques'
- HIGH Hugging Face cryptomining models return days after takedown; fake Solana kit baits AI coding agents
- HIGH Tailscale: 11 flaws dropped via full disclosure - SSH race gives root on other nodes

+ 9 more in the sections below

CROSS-SECTOR / ENTERPRISE IT

26 items

- CRIT Cisco Catalyst SD-WAN auth bypass CVE-2026-20127 exploited by UAT-11473 to plant KeyDrift
- CRIT Citrix NetScaler CVE-2026-107406: SAML IdP/SP memory overflow RCE - affects builds just rushed out
- CRIT EDK II UEFI PXE pre-boot RCE CVE-2026-97631 - one packet runs code before Secure Boot
- CRIT Ivanti Connect Secure: two more chain CVEs (CVE-2026-111357, CVE-2026-118527) added to KEV
- CRIT Linux kernel CVE-2026-98432: TCP use-after-free gives remote root on MPTCP listeners
- CRIT Node2Shell / Brotli2Shell (CVE-2026-111497): Node.js bundled Brotli decoder RCE exploited (KEV)
- CRIT Oracle E-Business Suite CVE-2026-101767 (Oct CPU) exploited days after patch
- CRIT PHP2Shell (CVE-2026-109618 / CVE-2026-109619): PHP core pre-auth RCE now in CISA KEV

+ 18 more in the sections below

AUSTRALIA - SPECIFIC

Local orgs & data

Australian agencies got inside the Amadey loader backend; Operation Endgame-style disruption of Amadey/StealC

HIGH UNVERIFIED AU LawEnf Infostealer

Australian authorities reportedly gained access to the Amadey malware backend as part of the international action against the Amadey loader and StealC infostealer (~326 servers dismantled, ~142 domains seized). Amadey/StealC feed credential theft and ransomware initial access, so Australian victims identified from backend data may be notified. Action: treat any Amadey/StealC detections in the last 90 days as credential-compromise events (reset, revoke sessions, review MFA).

Refs: thehackernews.com

Nefilim/Hive affiliate Artem Stryzhak sentenced to 70 months - Nefilim hit Australian organisations

MEDIUM UNVERIFIED AU Ransomware LawEnf

Ukrainian national Artem Stryzhak was sentenced in the US to 70 months after pleading guilty to conspiracy charges. As a Nefilim affiliate (2021) he hit organisations in the US, Canada and Australia, and later worked with Hive (losses >USD 100M). Co-conspirator Volodymyr Tymoshchuk (also tied to LockerGoga and MegaCortex) remains at large. Relevant to Australian victims of 2021 Nefilim intrusions.

Refs: therecord.media

APAC - SPECIFIC

Regional incidents & actors

Binance loses ~USD 6.3B in largest crypto theft on record - attributed to DPRK TraderTraitor

CRITICAL VERIFIED DPRK Lazarus Crypto

On 29 Oct ~USD 6.3B (TRM Labs: ~6.36B) was drained from Binance wallets, mostly within ~20 minutes. TRM Labs and Chainalysis attribute it to TraderTraitor (UNC4899 / Jade Sleet, Lazarus cluster). Binance initially cited a compromised DevOps engineer laptop, later calling it a multi-layered composite attack; ~USD 3B frozen and user losses to be covered. Follow-on phishing already exploits the crisis (fake French DGFiP letters with QR codes). Lesson: developer/DevOps endpoints with signing or hot-wallet access are the target.

Refs: bleepingcomputer.com · malwarebytes.com · mcafee.com

Capcom ID breach confirmed: 11.77M accounts (emails, last IP, login metadata)

HIGH VERIFIED Japan Gaming

Capcom confirmed 11,774,247 CAPCOM ID accounts exposed: email, creation date, last login, login count and last IP address (DOB/gender/country for 43 users). No passwords or cards per Capcom, but the intruder changed passwords on 196 accounts. Reported to Osaka police; vector and actor undisclosed. Phishing using Capcom branding expected.

Refs: bleepingcomputer.com · securityweek.com · malwarebytes.com

Japan incident wave: JAL (via Amadeus, ~92,000 customers) and Sony Network Communications (~2.5M records)

HIGH VERIFIED Japan ThirdParty

Japan Airlines disclosed a third-party breach traced to Amadeus exposing passport numbers, frequent-flyer numbers, emails and phone numbers (later reporting puts it at ~92,000 customers; ANA and other Asian carriers also cited). Sony ISP subsidiary Sony Network Communications (So-net/NURO) disclosed a ~2.5M-record breach. The Record frames these as part of a run of concurrent Japanese incidents (GMO, IDCF Cloud, Burger King Japan). Expect passport-themed phishing.

Refs: bleepingcomputer.com · therecord.media · scworld.com

NetamLoader: .NET loader aimed at a government-only custom Windows 10 build in Asia

HIGH VERIFIED APT Asia Loader

Kaspersky GReAT disclosed a sophisticated chain against Asian government organisations that specifically targets a custom Windows 10 build used only by government entities - implying prior knowledge of the target environment. Payload is a previously undocumented .NET assembly-loading framework, NetamLoader, which injects modules in memory. No CVE or public attribution yet.

Refs: thehackernews.com · kaspersky.com · borncity.com

Volt Typhoon used 'Silent Train' on-demand relay chains to hide four zero-day campaigns

HIGH VERIFIED China APT ORB

China-nexus Volt Typhoon builds rotating chains of devices compromised on demand (ORB-style) - called Silent Train - to conceal zero-day attacks on enterprise control planes and critical infrastructure; Lumen ties the network to four zero-day campaigns. It evolves the KV-botnet SOHO-router model disrupted in 2024: chains are assembled per operation and make foreign attacks look like domestic traffic. Detection must be behavioural (LOTL), not IOC-based.

Refs: bleepingcomputer.com · nextgov.com · csoonline.com

eMudhra (India) exits the CA business after weak intermediate keys - one private key was literally 4

HIGH VERIFIED India PKI

Scott Helme showed eight eMudhra intermediate CA private keys were trivially recoverable from public certificates. Mozilla and Chrome treat them as compromised; browsers blocked 6 TLS intermediates and Microsoft OOB updates distrusted 2 code-signing certs (CVE-2026-111943 / CVE-2026-111944). Go 1.27.3 / 1.26.10 block the chains. Action: inventory certificates chaining to eMudhra and re-issue from another CA.

Refs: therecord.media · blog.qualys.com · schneier.com

Microsoft: North Korean actors at varying AI-adoption stages across the kill chain

MEDIUM VERIFIED DPRK AI ITWorkers

Microsoft rates DPRK groups (Jade, Coral, Jasper, Diamond, Onyx, Pearl, Emerald, Sapphire Sleet) by AI adoption across reconnaissance, social engineering, tooling and operations, including AI-assisted IT-worker personas; an agentic pentest framework (ARTEX) is reported for Onyx and Pearl Sleet. Same week: US Treasury sanctioned Russian and North Korean nationals laundering DPRK IT-worker earnings - screen contractor payees against OFAC SDN updates.

Refs: microsoft.com · news.sbs.co.kr · therecord.media

Dark-web claims: Indonesia President's Office documents and Malaysian Customs webshell access for sale

MEDIUM UNVERIFIED Indonesia Malaysia DarkWeb

Unconfirmed leak-forum posts (1 Nov): actor 'Sarxeyel' claims ~679,000 documents linked to Indonesia's Office of the President; a seller offers webshell access plus database for Malaysian Customs. Same roundup: EscapadaRural (Spain, 31.1M records), QiCard (Iraq), Venezuelan .gov mailbox credentials. Treat as claims until victims confirm.

Refs: x.com/DailyDarkWeb

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

Patch now

Adobe Commerce / Magento CVE-2026-48356 added to CISA KEV

CRITICAL VERIFIED Adobe Magento KEV

CISA added CVE-2026-48356 (July 2026 Adobe bulletin; Adobe Commerce/Magento, also listed for Experience Manager) to KEV on 27 Oct - exploited in the wild. Confirm all Commerce/Magento instances are on the July 2026 fixed releases or later.

PoC: Active exploitation in the wild (CISA KEV 2026-10-27)

Refs: cyber.gc.ca · action1.com · securityonline.info

Canonical LXD / MicroCloud CVE-2026-112816 (CVSS 10): trusted-client impersonation

CRITICAL VERIFIED LXD Ubuntu

Anyone who can reach the LXD HTTPS API and knows a trusted client's public certificate can authenticate as that client without its private key, giving cluster and VM/container control and effectively host root. Not reported exploited. Update LXD/MicroCloud and restrict the API (port 8443) to management networks.

Refs: thehackernews.com · discourse.ubuntu.com · raw.githubusercontent.com

Cisco Catalyst SD-WAN auth bypass CVE-2026-20127 exploited by UAT-11473 to plant KeyDrift

CRITICAL VERIFIED Cisco SD-WAN APT

Cisco Talos tracks new APT UAT-11473 exploiting an authentication bypass in Catalyst SD-WAN Controllers to deploy KeyDrift, a custom framework that harvests SD-WAN encryption keys. Patch controllers, restrict management-plane access, and rotate SD-WAN keys/certificates on any controller exposed before patching.

PoC: Active exploitation in the wild (UAT-11473 / KeyDrift)

Refs: bleepingcomputer.com · thehackernews.com · labs.cloudsecurityalliance.org

Citrix NetScaler CVE-2026-107406: SAML IdP/SP memory overflow RCE - affects builds just rushed out

CRITICAL VERIFIED Citrix NetScaler

Memory overflow in NetScaler ADC/Gateway configured as SAML IdP or SP allows RCE or DoS. Not yet exploited, but three other NetScaler bugs are, and the builds many orgs just patched to are also affected. Upgrade to the newest recommended builds.

Refs: thehackernews.com · securityweek.com · cyber.gc.ca

Drupal Commerce Core access bypass CVE-2026-118539 (Highly Critical) exploited against stores

CRITICAL VERIFIED Drupal eCommerce

SA-CONTRIB-2026-254: access bypass in Commerce Core is being exploited against online stores, part of a batch of 39 Drupal advisories. Update Commerce Core immediately; Centarro has published order-audit checks to spot fraudulent orders/price manipulation.

PoC: Active exploitation in the wild

Refs: bleepingcomputer.com · securityweek.com · thehackernews.com

EDK II UEFI PXE pre-boot RCE CVE-2026-97631 - one packet runs code before Secure Boot

CRITICAL VERIFIED UEFI Firmware

Critical (reported CVSS 9.5) flaw in TianoCore EDK II NetworkPkg PXE driver, ~16 years old, lets an adjacent attacker execute code before the OS loads. Fix merged upstream but every OEM/IBV must ship firmware, so exposure will persist for months. Disable PXE/network boot where not required and isolate provisioning VLANs; Hetzner and others have issued interim measures.

Refs: govinfosecurity.com · securityaffairs.com · it-connect.fr

GitLab CVE-2026-97229 (CVSS 10) unauthenticated CI/CD regex RCE added to CISA KEV

CRITICAL VERIFIED GitLab KEV CI/CD

Integer overflow in GitLab's CI/CD regular-expression compiler lets an unauthenticated user run code on the server via a crafted regex. CISA added it to KEV on 29 Oct - now exploited in the wild. Upgrade to 19.2.8 or the matching fixed release; no workaround. Hunt for unexpected runner/admin tokens and new SSH keys on self-managed instances.

PoC: Active exploitation in the wild (CISA KEV 2026-10-29)

Refs: bleepingcomputer.com · thehackernews.com · cyber.gc.ca

Ivanti Connect Secure: two more chain CVEs (CVE-2026-111357, CVE-2026-118527) added to KEV

CRITICAL VERIFIED Ivanti KEV VPN

Follow-up to the UTA0576 zero-day chain (CVE-2026-104935 auth bypass + RCE) that gave unauthenticated root on fully patched appliances. CISA added CVE-2026-111357 and CVE-2026-118527 to KEV on 30 Oct. Fixed builds: Connect Secure 25.1.1.3, 25.1.3.1, 22.8R2.6 (also Neurons Patch for Intune and Xtraction). Run Ivanti's integrity checker and treat pre-patch appliances as compromised.

PoC: Active exploitation in the wild (CISA KEV 2026-10-30)

Refs: cyber.gc.ca · securityweek.com · thehackernews.com

Linux kernel CVE-2026-98432: TCP use-after-free gives remote root on MPTCP listeners

CRITICAL VERIFIED Linux Kernel AI-found

Race in IPv4 TCP connection-request handling (tcp_v4_syn_recv_sock passes ireq_opt without copying). Anthropic's unreleased Claude model built a working exploit - KASLR bypass to unauthenticated remote root on a server with an MPTCP listener. Kernel CNA CVSS 9.8 (Red Hat 5.9, complex race). No ITW exploitation reported. Patch kernels; disable MPTCP where unused (net.mptcp.enabled=0).

PoC: Working exploit built by Anthropic (not publicly released) - openwall.com

Refs: bleepingcomputer.com · openwall.com · cyber.gc.ca

Node2Shell / Brotli2Shell (CVE-2026-111497): Node.js bundled Brotli decoder RCE exploited (KEV)

CRITICAL VERIFIED Node.js KEV .NET

Out-of-bounds write in the Brotli decoder bundled with the Node.js runtime (not the npm package), found by OpenAI Codex Security. RCE now confirmed on stock x86-64 as well as arm64. CISA added it to KEV on 27 Oct; .NET received OOB fixes, PAN-OS fixes due 30 Oct, Cloudflare workerd DoS-only. Fixed: Node 22.23.4 / 24.22.1 / 26.12.1; EoL lines 20/23/25 will not be fixed - upgrade them.

PoC: Public - Imperva RCE writeup vs Node.js 24.22.0; exploitation in the wild (KEV) - imperva.com

Refs: bleepingcomputer.com · imperva.com · thehackernews.com

Oracle E-Business Suite CVE-2026-101767 (Oct CPU) exploited days after patch

CRITICAL VERIFIED Oracle EBS

Attackers began scanning for and exploiting unpatched Oracle EBS roughly ten days after the October 2026 Critical Patch Update; CCCS updated its CPU advisory to flag CVE-2026-101767 as exploited. Apply the Oct CPU to EBS now and keep EBS web tiers off the internet; review for new responsibilities/users and outbound connections.

PoC: Active exploitation in the wild

Refs: bleepingcomputer.com · securityweek.com · thehackernews.com

PHP2Shell (CVE-2026-109618 / CVE-2026-109619): PHP core pre-auth RCE now in CISA KEV

CRITICAL VERIFIED PHP KEV RCE

Stale internal state after an out-of-memory abort gives unauthenticated RCE from one HTTP request via session upload progress (on by default). Highest risk: Apache mod_php with defaults; also confirmed on PHP-FPM via app code. Hits every PHP stack (WordPress, Drupal, Magento). Added to KEV 26 Oct; Amazon says exploitation began 4 days before patches. Fixed in PHP 8.5.12 / 8.4.27 / 8.3.36 / 8.2.35; 8.1 and older unfixed. CVE-2026-115560 is NOT fixed by the Oct 21 releases - set session.upload_progress.enabled=0. Wiz: exposed vulnerable hosts down ~67% in a week, but general end-to-end public exploits remain unreliable.

PoC: Public - exploit kit 9bie/php2shell-bypass-aslr-exp and a Go 'PHP2Shell' tool; active exploitation in the wild (KEV) - wiz.io

Refs: bleepingcomputer.com · wiz.io · tenable.com

Popcorn Time updater CVE-2026-30612: abandoned HTTP update domain = SYSTEM/root RCE on millions

CRITICAL VERIFIED SupplyChain Updater

Eye Security found Time4Popcorn updaters polling the abandoned domain popcorntimeupd[.]xyz over plain HTTP and running unsigned binaries as SYSTEM/root. Eye registered the domain and saw up to 3M Windows and 350k macOS clients, including corporate, government and military networks, then pushed a benign payload disabling the updater. Hunt for Popcorn Time installs and DNS lookups of the domain.

Refs: bleepingcomputer.com · securityweek.com · malwarebytes.com

VMware CVE-2026-41709 (VMSA-2026-0006.1) added to CISA KEV

CRITICAL VERIFIED VMware KEV

CISA added CVE-2026-41709 to KEV on 28 Oct. The Broadcom advisory also covers CVE-2026-59309 (critical vCenter authentication bypass, CVSS 9.8), CVE-2026-59310, CVE-2026-47876 and CVE-2026-41703 across vCenter, ESX, Workstation, Fusion and Cloud Foundation. Patch vCenter/ESX first; keep vCenter off user networks.

PoC: Active exploitation in the wild (CISA KEV 2026-10-28)

Refs: nvd.nist.gov · cyber.gc.ca · cve.org

Apple backports exploited CoreGraphics fix CVE-2026-86950 to iPhone XS/XR (iOS 18.7.11)

HIGH VERIFIED Apple iOS

Apple shipped iOS/iPadOS 18.7.11 for iPhone XS, XS Max, XR and iPad 7th gen, backporting the CoreGraphics zero-day (CVE-2026-86950) exploited in targeted attacks. Separately the October release (iOS 27.2 etc.) fixed 304 flaws with none newly flagged as exploited. Update legacy fleet devices or retire them.

PoC: Active exploitation in targeted attacks

Refs: thehackernews.com · malwarebytes.com · securityonline.info

Cisco ASA/FTD SSL VPN zero-day CVE-2026-76418 exploited to crash firewalls (KEV)

HIGH VERIFIED Cisco KEV VPN

DoS in the remote-access SSL VPN of ASA and Firepower Threat Defense is exploited to reload firewalls - the second Cisco firewall VPN zero-day since August. Added to KEV 29 Oct. Patch; monitor for unexpected reloads and crash files.

PoC: Active exploitation in the wild (CISA KEV 2026-10-29)

Refs: bleepingcomputer.com · securityweek.com · networkworld.com

WordPress 7.1.4 fixes 22 flaws; update-window bug attacked within 9 minutes

HIGH VERIFIED WordPress

WordPress 7.1.4 (28 Oct) fixes 22 vulnerabilities including a flaw exposing a site during its update process. Wordfence saw 18,500+ suspicious requests starting ~9 minutes after release. Ensure auto-updates completed and check for unexpected admin users or files.

PoC: Exploitation attempts observed in the wild (Wordfence)

Refs: wordpress.org · it-connect.fr · clubic.com

wolfSSL WolfProt CVE-2026-59106: unauthenticated OS command injection (CVSS 9.3)

CRITICAL UNVERIFIED wolfSSL Embedded

Unsanitised network input reaches a shell in wolfSSL's WolfProt interface - unauthenticated RCE. Affected/fixed versions not yet stated in public reporting; the CVE record is published. Inventory embedded/IoT products using WolfProt and watch for vendor firmware.

Refs: raw.githubusercontent.com · securityonline.info

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity

Android 'SMS of Death' CVE-2026-58882: crafted SMS crashes phones, can block emergency calls

HIGH VERIFIED Android DoS

Zero-click remote DoS: a crafted text disrupts cellular service or traps unpatched Android phones in a reboot loop until factory reset, and can drop emergency calls. Already patched in Android security updates; a researcher has released a PoC. Enforce current patch level on managed devices.

PoC: Public - researcher PoC released - bleepingcomputer.com

Refs: bleepingcomputer.com · cybernews.com · esecurityplanet.com

Tailscale: 11 flaws dropped via full disclosure - SSH race gives root on other nodes

HIGH VERIFIED Tailscale VPN

Researcher Erica Windisch published 11 Tailscale vulnerabilities without coordinated disclosure. Headline: Tailscale SSH race conditions let one compromised tailnet device gain root on other servers running Tailscale SSH and add a rogue node. Tailscale confirmed the SSH flaws and shipped fixes within ~24h. Update clients; review tailnet ACLs and SSH rules.

Refs: bleepingcomputer.com · thehackernews.com · tailscale.com

Telegram for Android: answering a voice call could trigger code execution

HIGH VERIFIED Telegram Android

NebuSec published details of a Telegram Android flaw that allowed code execution on the victim's phone when a call was answered; fixed by Telegram in late September. No CVE in reporting. Ensure managed Android devices run the current Telegram build.

Refs: thehackernews.com · clubic.com · digit.in

Browser and enterprise patch batch: Chrome 156 (4 critical), Firefox 159, Juniper, Progress, Veeam, WatchGuard, TeamViewer

HIGH UNVERIFIED Chrome Firefox PatchBatch

Chrome 156.0.8078.73/.74 fixes 52 issues incl. 4 critical UAFs (some credited to OpenAI Codex Security); Firefox 159 / ESR 115.44 / 153.6 and Thunderbird also updated. Same day CCCS flagged Juniper, Progress, Tanium, Veeam, WatchGuard and TeamViewer advisories, plus HashiCorp, Mattermost, n8n and Laravel MongoDB (<5.12.0) on 29-30 Oct.

Refs: cyber.gc.ca · malwarebytes.com

ICS advisories: Hitachi, Johnson Controls, Moxa and Esri

MEDIUM UNVERIFIED ICS OT

CCCS republished control-system advisories for Hitachi (AV26-1091), Johnson Controls (AV26-1090), Moxa (AV26-1089) and Esri (AV26-1088), incl. CVE-2026-111459/111460/111461. Map to OT asset inventory and schedule maintenance-window patching; keep these devices off the internet.

Refs: cyber.gc.ca

Intelbras IP cameras: unauthenticated firmware-upgrade endpoint enables LAN DoS

MEDIUM UNVERIFIED IoT Camera

Kaspersky GReAT: /firmwareUpgrade_service/Demo skips auth and validation and reboots the camera; repeated requests give indefinite DoS from the local network (CAN-2026-2035970, CVE pending). Several iM-series models; fixed in firmware R.260804.

Refs: securelist.com

GLOBAL - SOFTWARE SUPPLY CHAIN

Extensions, models, vendors & PaaS

Tampered Claude Code VS Code extension (2.1.312 / 2.1.313) on Cursor marketplace planted SSH backdoors

CRITICAL VERIFIED IDE Extension DevTools

Two tampered builds of the Claude Code extension were live on Cursor's marketplace (~11 hours on 29 Oct) and installed a persistent reverse-SSH backdoor; up to ~5,000 developer systems exposed, infected Macs observed. Anthropic says it did not build or publish those builds; 2.1.314 does NOT remove existing infections. Hunt for the C2 IP and VSIX hashes in the IOC table, inspect authorized_keys and launch agents/services, and rotate any credentials on affected machines.

Refs: doublepulsar.com · bleepingcomputer.com · helpnetsecurity.com

Hugging Face cryptomining models return days after takedown; fake Solana kit baits AI coding agents

HIGH VERIFIED ML HuggingFace AI

Pluto Security traced a self-iterating campaign across 31 Hugging Face repos using trust_remote_code to hijack GPU servers for mining and plant backdoors; one model passed 28,000 downloads and it returned days after takedown. Separately a fake Solana starter kit on GitHub is positioned to trick AI coding agents into installing NetSupport RAT. Never enable trust_remote_code on unvetted repos; prefer safetensors and scan pickles.

Refs: bleepingcomputer.com · pluto.security · thenextweb.com

Polymarket third-party script drained wallets and sold positions; ~USD 2.7M refunded

HIGH VERIFIED Magecart Crypto

A compromised third-party service injected crypto-draining JavaScript into Polymarket's frontend; simply loading a page drained some wallets, and on 29 Oct the script sold signed-in traders' positions (session riding). ~USD 2.64M reached attacker wallets; Polymarket halted trading and is refunding ~USD 2.7M to 726 wallets. Second third-party frontend compromise for the platform.

Refs: bleepingcomputer.com · thehackernews.com · clubic.com

Warp terminal: vendor breach exposed AI agent decision logs and user telemetry

HIGH VERIFIED AI DevTools ThirdParty

Warp disclosed that an attack on a third-party vendor exposed agent decision logs and telemetry. CSA notes agent traces can contain commands, file paths, secrets and internal hostnames - treat them as crown-jewel data. Review Warp privacy settings and rotate any secrets that may have appeared in agent sessions.

Refs: bleepingcomputer.com · labs.cloudsecurityalliance.org · fleetdm.com

Fake ChatGPT and Claude desktop installers on GitHub bundle malware beside real signed installers

MEDIUM VERIFIED GitHub AI-lure

Fake GitHub repositories ship archives containing the genuine signed OpenAI/Anthropic installer plus a trojanised file that installs hidden malware (cryptominer; Help Net names it Yoba). Download AI desktop apps only from vendor sites; block execution from user Downloads via allow-listing where possible.

Refs: helpnetsecurity.com · itpro.com · clubic.com

Northflank breach: customers told to rotate all secrets after AI API keys abused

HIGH UNVERIFIED PaaS LLMjacking

Cloud platform Northflank told customers to rotate every credential and secret stored on the platform after a breach; stolen secrets were used for unauthorised use of customers' AI API keys (LLMjacking). If you deploy on Northflank, rotate now and review model-provider billing.

Refs: bleepingcomputer.com · govery.com

UK watchdog: police ICT suppliers repeatedly breached; contracts lack ongoing assurance

MEDIUM UNVERIFIED UK ThirdParty

HMICFRS found multiple cyberattacks against third-party ICT suppliers holding UK police data. Police Digital Service logged 252 incidents and 796 near misses in Q1; most supplier contracts lacked ongoing security assurance and supplier logs were often invisible to in-house teams.

Refs: therecord.media

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

Node2Shell RCE writeup and PoC inputs (Imperva) for CVE-2026-111497

CRITICAL VERIFIED Exploit Node.js

Imperva published the Brotli-data-to-RCE technique against the official Node.js 24.22.0 build; RCE subsequently confirmed on x86-64. Use it to validate that runtimes and container base images are on 22.23.4 / 24.22.1 / 26.12.1.

PoC: Public - Imperva RCE writeup - imperva.com

Refs: imperva.com · semgrep.dev · thehackernews.com

PHP2Shell exploit tooling: 9bie/php2shell-bypass-aslr-exp and a Go 'PHP2Shell' port

CRITICAL VERIFIED Exploit PHP

Public exploit kit for CVE-2026-109618/109619 (worker pinning with ~399 stalled connections, ~974-part chunked multipart) calibrated for php:8.4.26-apache; a separate Go tool ports WoYinDao 'Chain A' session poisoning but needs an existing LFI. Wiz: unreliable over the internet but succeeded on single-worker mod_php honeypots. Detection strings are in the IOC table.

PoC: Public - exploit kit on GitHub (9bie/php2shell-bypass-aslr-exp) - wiz.io

Refs: wiz.io · bleepingcomputer.com · tenable.com

Android 'SMS of Death' PoC (CVE-2026-58882)

HIGH VERIFIED PoC Android

Researcher released a PoC message that remotely crashes or reboot-loops unpatched Android phones. Useful for testing MDM patch-compliance claims in a lab only.

PoC: Public - researcher PoC - bleepingcomputer.com

Refs: bleepingcomputer.com · cybernews.com · esecurityplanet.com

PortSwigger 'Scalable Vector Grief': 6 of 8 SVG sanitizers bypassed

HIGH UNVERIFIED XSS Research

Gareth Heyes bypassed six of eight SVG sanitizers using XSLT, Link-header and Safari/GIF techniques; DOMPurify and darylldoyle/svg-sanitizer held. Two popular apps were reportedly exploited with these techniques. Re-test any SVG upload path not using DOMPurify.

PoC: Public - research write-up with bypass payloads - portswigger.net

Refs: portswigger.net · x.com/garethheyes

Autonomous N-day exploit-generation pipeline (chompie, BSides Canberra) talk released

MEDIUM UNVERIFIED AI Exploit AU

Recording of a talk on an AI-agent pipeline that turns patches and advisories into working N-day exploits. With PHP2Shell built in ~a week and Anthropic's kernel exploit this week, patch-to-exploit windows keep collapsing.

Refs: x.com/BSidesCbr

Edge exploit chain built only from logic bugs (Intigriti Bug Bytes #241)

MEDIUM UNVERIFIED Browser Research

Bug Bytes #241 highlights a Microsoft Edge chain to calc.exe with no memory corruption, plus other web/RCE techniques this month. Logic-bug chains evade memory-safety mitigations; keep Edge on current channel.

Refs: intigriti.com

dawgyg to dump 4 months of Apple bug bounty reports and PoCs publicly

MEDIUM UNVERIFIED BugBounty Apple

Veteran hunter @thedawgyg says he will publish all data, PoCs and write-ups from four months of Apple testing - including unreported findings below Apple's bounty bar - inviting others to escalate them. Watch for Apple service issues becoming public before fixes.

PoC: Announced public PoC dump (planned 31 Oct - 1 Nov)

Refs: x.com/thedawgyg

Blue Initiative launches free maritime vulnerability database (~30,000 IT/OT CVEs)

INFO UNVERIFIED OT Tool Maritime

Maritime coalition index of ~30,000 vulnerabilities relevant to ships and ports, 37 in maritime-specific products. Useful for OT asset-to-CVE mapping in port/shipping environments.

Refs: securityweek.com

YARA-X 1.18 - 1.22 releases

INFO UNVERIFIED DFIR Tool

New YARA-X (Rust YARA) releases with improvements and bug fixes; YARA-X is becoming the default engine for detection rules. Update scanning pipelines and re-validate rule sets.

Refs: isc.sans.edu

GLOBAL - MALWARE & CAMPAIGNS

319 Chrome extensions (13.4M installs) hijacked searches through tracking servers

HIGH VERIFIED Browser Extensions

Socket found 319 mostly fake PDF and search-tool extensions, promoted via Google Ads and largely unlisted, routing default searches through operator servers before Yahoo/Bing - exposing queries and earning referral revenue. Enforce an extension allow-list via Chrome policy.

Refs: bleepingcomputer.com · malwarebytes.com · tomsguide.com

Dahua camera campaign: 14,500+ cameras hijacked in 35 days (CERT-UA warning)

HIGH VERIFIED IoT Camera Ukraine

A 35-day campaign compromised more than 14,500 Dahua web cameras via default/reused credentials, authentication bypasses and P2P cloud abuse; CERT-UA warns cameras in Ukraine were hijacked (camera feeds are a known targeting aid). Disable P2P, change credentials, update firmware and segment cameras.

Refs: bleepingcomputer.com · therecord.media · thehackernews.com

UNC6671 (BlackFile-linked) help-desk vishing hits hedge funds and PE firms; CCCS alert AL26-028

HIGH VERIFIED Vishing Extortion ADCS

Extortion group UNC6671 is tied to attacks on hedge funds, private-equity and other financial firms via help-desk voice phishing; CCCS issued AL26-028 on an ongoing campaign. Microsoft IR separately documents Teams help-desk impersonation leading to AD CS abuse (ESC1/ESC8). Require call-back verification for resets and audit certificate templates.

Refs: bleepingcomputer.com · cyber.gc.ca · microsoft.com

Wallet stealers: fake Firefox add-ons (Phantom, Jupiter, Bitget) and fake 'Padre Terminal' iOS app

HIGH VERIFIED Crypto Extensions iOS

Malicious Firefox extensions impersonating Phantom, Jupiter and Bitget steal wallet secrets; separately a fake crypto app that passed App Store review is linked to ~USD 23K in wallet theft. Restrict browser add-ons on finance/treasury endpoints.

Refs: malwarebytes.com · socket.dev · bleepingcomputer.com

WardenStealer: 130K+ infections harvesting AI coding-tool tokens and API keys

HIGH VERIFIED Infostealer AI

SpyCloud counts >130,000 unique WardenStealer infections since 3 Aug; Rust-based WardenStealer and Aoki logs contain AI assistant/IDE session cookies, OAuth tokens and API keys alongside browser creds. Shorten AI-tool token lifetimes and add them to infostealer response playbooks.

Refs: spycloud.com · socprime.com · dailysecurityreview.com

Virtualine bulletproof hosting domain seized by FBI

MEDIUM VERIFIED BPH LawEnf

US law enforcement seized the main domain of Virtualine, a bulletproof host used by ransomware and other crime; TRM Labs says it led the BPH sector in illicit inflows. The service was partly still online after the seizure - keep its ranges on blocklists.

Refs: bleepingcomputer.com · securityweek.com · trmlabs.com

Fortinet 'k0t' mass compromise grows: 924 more firewalls, 40,573 cleartext secrets

HIGH UNVERIFIED Fortinet Credentials

Hudson Rock says actor k0t compromised 924 more FortiGates than first reported, harvesting 40,573 cleartext secrets incl. 1,576 AD LDAP bind passwords from LDAP/SSL-VPN configs. Vector not stated. Rotate LDAP bind accounts used by FortiGates and restrict their AD rights.

Refs: x.com/IntCyberDigest

Apple sends mercenary-spyware threat notifications to users in 99 countries

MEDIUM UNVERIFIED Spyware iOS

New wave of Apple threat notifications; recipients include Lebanese journalist Radwan Mortada. Vendor/exploit chain not named. Enable Lockdown Mode for high-risk staff.

Refs: x.com/IntCyberDigest

ClickFix keeps coming: new fake-verification campaign (SANS ISC)

MEDIUM UNVERIFIED ClickFix Phishing

Another ClickFix campaign tricks users into pasting commands into Win+R or a terminal. Block or alert on explorer.exe-spawned PowerShell/mshta from the Run dialog.

Refs: isc.sans.edu

Election scam wave ahead of US midterms; FEC website targeted

MEDIUM UNVERIFIED Election Smishing

Malwarebytes lists voter-registration smishing, fake donations, paid surveys and fake electoral fines; the US FEC website was reportedly hit by a cyberattack about a week before the midterms (no attribution).

Refs: malwarebytes.com · clubic.com

Talos IR Q3 2026: help-desk vishing up, ransomware engagements rise

MEDIUM UNVERIFIED Trends Ransomware

Phishing remained the top initial-access vector, with actors increasingly impersonating IT help desks; ransomware engagements increased quarter on quarter.

Refs: blog.talosintelligence.com

VOLTA infostealer sends victim data to an LLM to rank who to monetise first

MEDIUM UNVERIFIED Infostealer AI

Talos: self-deleting Windows stealer (passwords, cookies, cards, seed phrases, Microsoft OAuth tokens, SSH/cloud keys) ships a victim 'evidence bundle' to an LLM via OpenRouter to prioritise monetisation, with a fallback model chain on refusal.

Refs: blog.talosintelligence.com

ZloyRAT Android trojan uses fuel, VPN and drone-radar lures in Russia (F6)

MEDIUM UNVERIFIED Android RAT

Apps showing fuel availability, a fake government 'GosuVPN' and 'Drone Radar' deliver ZloyRAT, which steals SMS/notifications and targets 60+ Russian banking apps and Telegram.

Refs: therecord.media

Syrian Electronic Army member 'Th3Pr0' sentenced to 42 months

INFO UNVERIFIED LawEnf Hacktivist

Ahmad Umar Agha was sentenced in E.D. Virginia for the SEA conspiracy (2013 AP Twitter hijack and ~47 media/NGO victims).

Refs: therecord.media

GLOBAL - NOTABLE BREACHES

Florida Student Financial Aid site breach: ~4.9M applicants incl. SSNs and DOBs

CRITICAL VERIFIED PII SSN

FLDOE learned of the breach on 19 Oct and disclosed on 29 Oct: names, addresses, phones, email, SSNs and DOBs of ~4.9M aid applicants. Site taken down; FDLE and Florida Digital Service engaged. Expect identity-fraud and student-aid phishing.

Refs: therecord.media · govtech.com · floridaphoenix.com

UNM Health cyber incident: patients diverted, 30+ clinics closed

CRITICAL VERIFIED Healthcare Ransomware

University of New Mexico Health diverted ambulances from its main Albuquerque hospital and cancelled appointments at 30+ clinics; pattern consistent with ransomware, systems later brought back online. No actor claimed yet - watch leak sites.

Refs: therecord.media · securityweek.com · abqjournal.com

Belgium FPS Finance takes MyMinfin offline after cyberattack; tax deadline extended

HIGH VERIFIED Government Europe

Belgium's finance ministry suspended MyMinfin and other online services ahead of a filing deadline; it later said no data leaked while services remained down.

Refs: therecord.media · euronews.com · brusselstimes.com

Chainalysis breached by 'offensive agentic techniques'

HIGH VERIFIED AI Agentic

Chainalysis says an external actor used AI-agent-driven techniques to reach internal systems and tools, exposing customer names, emails, user IDs and roles; investigation data, credentials and session tokens reportedly not accessed. One of the first victim disclosures explicitly attributing an intrusion to agentic AI.

Refs: chainalysis.com · bleepingcomputer.com · thehackernews.com

Data on 41,000+ DHS (mostly ICE/CBP) employees published by 'Department of Peace'

HIGH VERIFIED Government Hacktivist

Names, work emails, phones, titles and group memberships published with DDoSecrets; the group claims access via an Okta SSO service - Okta says no evidence of platform compromise. Doxxing and targeted phishing risk for federal staff.

Refs: malwarebytes.com · gizmodo.com · decrypt.co

Moldova government systems breached; data of ~750,000 people reportedly stolen

HIGH VERIFIED Government Europe

PM Vasile Tofan says the attack may be part of a wider campaign against citizens' data and government infrastructure; foreign involvement under investigation. Reporting puts stolen records at ~750,000 people.

Refs: therecord.media · rferl.org · unn.ua

Quest Diagnostics: Quanum Lab Services Manager accessed, patient records exposed

HIGH VERIFIED Healthcare PHI

Regulatory filing: an unauthorised party accessed the Quanum test-ordering platform affecting certain patient records; count, vector and actor not disclosed.

Refs: securityweek.com · therecord.media · bleepingcomputer.com

Charite Berlin: web server breach exposes staff, student and contact data

MEDIUM VERIFIED Healthcare Germany

Attackers took names and emails (and reportedly usernames) of staff, students and external contacts from a Charite web server; the hospital says no health data affected and filed a complaint.

Refs: computerbase.de · berliner-zeitung.de · stuttgarter-zeitung.de

Holcim listed on Emperador ransomware leak site

HIGH UNVERIFIED Ransomware LeakSite

Emperador added Swiss building-materials multinational Holcim (Lafarge, Aggregate Industries, Firestone Building Products) to its leak site; no confirmation or data volume yet.

Refs: x.com/DailyDarkWeb

Revolve Group 8-K: saved payment cards scraped via automated account access

HIGH UNVERIFIED Retail PCI

Attackers used automated means (credential stuffing pattern) to pull names, contact info, card numbers and expiry dates for customers with saved cards; 127,200 Texas residents among those notified.

Refs: sec.gov · therecord.media

CTS Strasbourg transport: ~230,000 customer accounts stolen

MEDIUM UNVERIFIED Transport France

Customer account data stolen; passwords and bank details reportedly not taken but exposed data enables targeted phishing.

Refs: clubic.com

Cyprus GigaVoucher grant programme: ~72,920 records leaked

MEDIUM UNVERIFIED Government Leak

A threat actor published a CSV said to come from the Cyprus government Connectivity Grant (GigaVoucher) programme; authenticity unconfirmed.

Refs: x.com/DailyDarkWeb

Engie partner sales tool breached; customer contract references stolen

MEDIUM UNVERIFIED Energy ThirdParty

Attackers accessed the tool used by Engie's door-to-door partner salespeople; contact details and contract references stolen - Engie warns of fake-advisor scams.

Refs: clubic.com

Scribd (Slideshare/Everand) breach notices: emails, payment history, card last-4

MEDIUM UNVERIFIED Consumer

Breach disclosed 1 Oct; notification letters still arriving a month later. Victim count not disclosed.

Refs: x.com/IntCyberDigest

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
`134.209.82[.]225`	IPv4	Tampered Claude Code ext 2.1.312/2.1.313 reverse SSH (22) and C2 (8099 /beacon)	doublepulsar.com
`432ccdee3801f99e52b8fe31f69ea9870118e96ea7ef9ecabed1479621b5ab62`	SHA-256	Malicious Claude Code VSIX (darwin-arm64)	doublepulsar.com
`3de1722901165769893bef57c72594e9a54459faa23f3091b136b79966edd081`	SHA-256	Malicious Claude Code VSIX (win32-x64)	doublepulsar.com
`Claude Code VS Code ext 2.1.312 / 2.1.313 (Cursor/OpenVSX)`	Package	Tampered builds - 2.1.314 does not remove infection	bleepingcomputer.com
`31.56.197[.]72`	IPv4	PHP2Shell C2 / payload host (Wiz)	wiz.io
`85.11.187[.]35`	IPv4	PHP2Shell exploitation source (Wiz)	wiz.io
`172.206.2[.]199`	IPv4	PHP2Shell exploitation source (Wiz)	wiz.io
`3.37.227[.]134`	IPv4	PHP2Shell exploitation source (Wiz)	wiz.io
`103.151.172[.]95`	IPv4	PHP2Shell exploitation source (Wiz)	wiz.io
`15.204.59[.]70 / 162.35.99[.]94`	IPv4	PHP2Shell exploitation sources (Wiz)	wiz.io
`178.249.214[.]6 / 135.136.19[.]197`	IPv4	PHP2Shell sources via VPN egress - alert, do not hard-block	wiz.io
`----php2shell-golang / PHP2SHELL_XBu4Je`	String	PHP2Shell Go tool multipart boundary / marker (UA Go-http-client/1.1)	wiz.io

Indicator	Type	Context	Reference
`popcorntimeupd[.]xyz`	Domain	Abandoned Popcorn Time update domain (CVE-2026-30612) - beaconing = installed updater	bleepingcomputer.com
`CVE-2026-109618 / CVE-2026-109619 / CVE-2026-115560`	CVE	PHP2Shell (KEV); 115560 unfixed - disable upload progress	cyber.gc.ca
`CVE-2026-111497`	CVE	Node2Shell Brotli RCE (KEV)	bleepingcomputer.com
`CVE-2026-97229`	CVE	GitLab CI/CD regex RCE (KEV)	bleepingcomputer.com
`CVE-2026-111357 / CVE-2026-118527`	CVE	Ivanti Connect Secure chain (KEV 30 Oct)	cyber.gc.ca
`CVE-2026-20127`	CVE	Cisco Catalyst SD-WAN auth bypass, UAT-11473 / KeyDrift	bleepingcomputer.com
`CVE-2026-76418`	CVE	Cisco ASA/FTD SSL VPN DoS zero-day (KEV)	bleepingcomputer.com
`CVE-2026-41709`	CVE	VMware (KEV 28 Oct)	cyber.gc.ca
`CVE-2026-101767`	CVE	Oracle EBS Oct CPU, exploited	bleepingcomputer.com
`CVE-2026-118539`	CVE	Drupal Commerce Core access bypass, exploited	bleepingcomputer.com
`CVE-2026-48356`	CVE	Adobe Commerce/Magento (KEV 27 Oct)	cyber.gc.ca
`CVE-2026-86950`	CVE	Apple CoreGraphics, exploited; backported to iOS 18.7.11	thehackernews.com

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH

Developer tooling is the new supply-chain front door

Why it matters: A tampered Claude Code extension backdoored up to ~5,000 dev machines, Binance's USD 6.3B loss reportedly began on a DevOps laptop, Warp agent logs leaked via a vendor, Northflank secrets were abused, fake AI installers sit on GitHub and Hugging Face models mine on GPUs.

Watch for: More marketplace (OpenVSX/Cursor) tampering, AI-agent-targeted lures (fake starter kits), and stolen AI API keys being resold. Pin extension versions and allow-list publishers.

HIGH

Runtime-level RCEs with KEV status: PHP2Shell and Node2Shell

Why it matters: Both live below the application, so every PHP or Node app inherits them; both reached KEV inside a week and CVE-2026-115560 remains unfixed. GitLab, Oracle EBS, Drupal Commerce and Adobe Commerce also went from patch to exploitation within days.

Watch for: Reliable public PHP2Shell chains, Node2Shell abuse in container images and appliances (PAN-OS, .NET), and EoL runtimes (PHP 8.1, Node 20/23/25) left exposed.

HIGH

AI on both sides of exploitation

Why it matters: An unreleased Claude model produced a working remote-root Linux exploit and chained browser/OS bugs; Chainalysis disclosed an intrusion by 'offensive agentic techniques'; VOLTA uses an LLM to prioritise victims; WardenStealer targets AI-tool tokens; DPRK groups are measured by AI adoption.

Watch for: Shrinking patch-to-exploit windows, agent-driven intrusion fingerprints (tempo, enumeration bursts), and AI-tool credentials in infostealer logs.

HIGH

Edge and network control planes keep getting hit

Why it matters: Ivanti chain CVEs added to KEV, Cisco SD-WAN exploited by UAT-11473 for key theft, a second ASA/FTD VPN zero-day, k0t's FortiGate haul of LDAP bind passwords, and Volt Typhoon's Silent Train relay chains hiding zero-days.

Watch for: Ivanti's outstanding fix, new SD-WAN/VPN KEV entries, and stolen device configs being used to pivot into AD.

MED

DPRK crypto theft at unprecedented scale

Why it matters: TraderTraitor's ~USD 6.3B Binance heist dwarfs Bybit; follow-on scams already impersonate tax authorities.

Watch for: Binance's technical post-mortem and IOCs, laundering via bridges/OTC desks, and copycat lures against exchanges and fintechs in APAC.

MED

Public-sector and healthcare data theft and outages

Why it matters: Florida (4.9M SSNs), DHS staff doxxing, Moldova (~750k), Belgium tax portal, UNM Health diversions, Quest and Charite in one week.

Watch for: Identity-fraud and election-themed phishing using these datasets, and ransomware leak-site claims for UNM Health.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	PHP 8.5.12/8.4.27/8.3.36/8.2.35 + session.upload_progress.enabled=0; Node 22.23.4/24.22.1/26.12.1 (+ .NET OOB, PAN-OS); GitLab 19.2.8+; Ivanti ICS 25.1.1.3/25.1.3.1/22.8R2.6; Cisco SD-WAN and ASA/FTD; VMware VMSA-2026-0006.1; Oracle Oct CPU (EBS); Drupal Commerce Core; Adobe Commerce July fixes; WordPress 7.1.4; LXD/MicroCloud; NetScaler; Linux kernel (CVE-2026-98432); iOS 18.7.11/27.2; Chrome 156 / Firefox 159; Tailscale; Android Oct patch.
Block IOCs	Import the IOC table into firewall/proxy/EDR/SIEM: block 134.209.82[.]225 and the PHP2Shell C2 31.56.197[.]72, alert on the other PHP2Shell sources and VPN egress IPs, hunt the two Claude Code VSIX SHA-256 hashes and versions 2.1.312/2.1.313, alert on DNS for popcorntimeupd[.]xyz and the PHP2Shell multipart strings, and add the listed CVEs to scanner priority. Re-fang indicators before importing.
Assume compromise	Developer machines that ran Claude Code ext 2.1.312/2.1.313 (check authorized_keys, launch agents, rotate all creds); internet-facing PHP mod_php, GitLab, Ivanti ICS, Cisco SD-WAN controllers and Oracle EBS exposed before patching; FortiGates - rotate LDAP bind accounts.
Third-party / supply chain	Allow-list IDE extensions and pin versions; block trust_remote_code for unvetted Hugging Face models; rotate secrets held on Northflank or other PaaS; inventory eMudhra-chained certificates; review third-party JavaScript on customer-facing sites (Polymarket pattern).
Harden	Call-back verification for help-desk resets and audit AD CS templates (ESC1/ESC8); disable PXE where unused; restrict LXD API, SD-WAN and VPN management to admin networks; enforce Chrome/Firefox extension policies; Lockdown Mode for high-risk staff; shorten AI-tool token lifetimes.